BÁO CÁO ĐỒ ÁN CHUYÊN NGÀNH HỌC KỲ II NĂM HỌC 2026 – 2027

Họ và tên: Lê Minh Nhật **MSSV: 2380601546**

Họ và tên: Nguyễn Minh Tuấn **MSSV: 2380602459**

Lớp: 23DTHB7 **Chuyên ngành: An Ninh Mạng** **Tuần số: 3**

Đề tài đăng ký: XÂY DỰNG HỆ THỐNG IAM DỰA TRÊN KEYCLOAK THEO ĐỊNH HƯỚNG ZERO TRUST

Nội dung báo cáo (các phần mà SV/nhóm đã tìm hiểu, trình bày chi tiết dưới đây).

1. Mục tiêu tuần 3

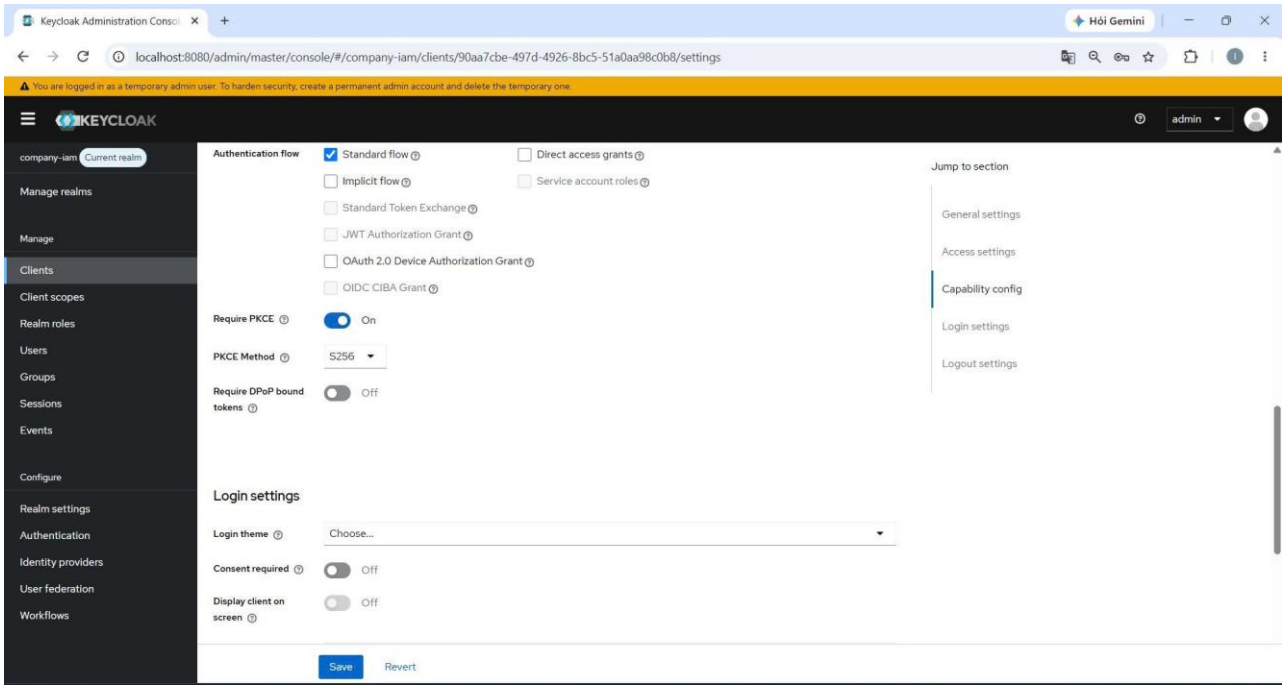
Kế thừa nền tảng IAM đã chuẩn bị ở các tuần trước, tuần 3 tập trung hoàn thiện và kiểm chứng Giai đoạn 2 – Web A và RBAC: cấu hình OIDC Client employee-portal với PKCE S256, Audience employee-api và ánh xạ vai trò; tích hợp đăng nhập, đăng xuất Keycloak vào Web A React; xác minh JWT và phân quyền tại Backend Express. Mục tiêu kiểm thử là phân biệt đúng HTTP 200, 401 và 403 theo tình trạng xác thực và quyền truy cập.

2. Các công việc đã thực hiện

2.1. Cấu hình OIDC Client và PKCE S256

Cấu hình employee-portal là public client dùng OpenID Connect và Authorization Code Flow; bắt buộc PKCE S256, không đặt client secret trong React và tắt Direct Access Grants. Redirect URI và Web Origin được giới hạn cho Web A tại http://localhost:5173. Frontend sử dụng keycloak-js với login-required và pkceMethod S256.

Kết quả: Web A chuyển người dùng đến Keycloak để đăng nhập; sau khi xác thực, ứng dụng nhận token và gọi API. Chức năng đăng xuất kết thúc phiên trình duyệt và chuyển về luồng đăng nhập.

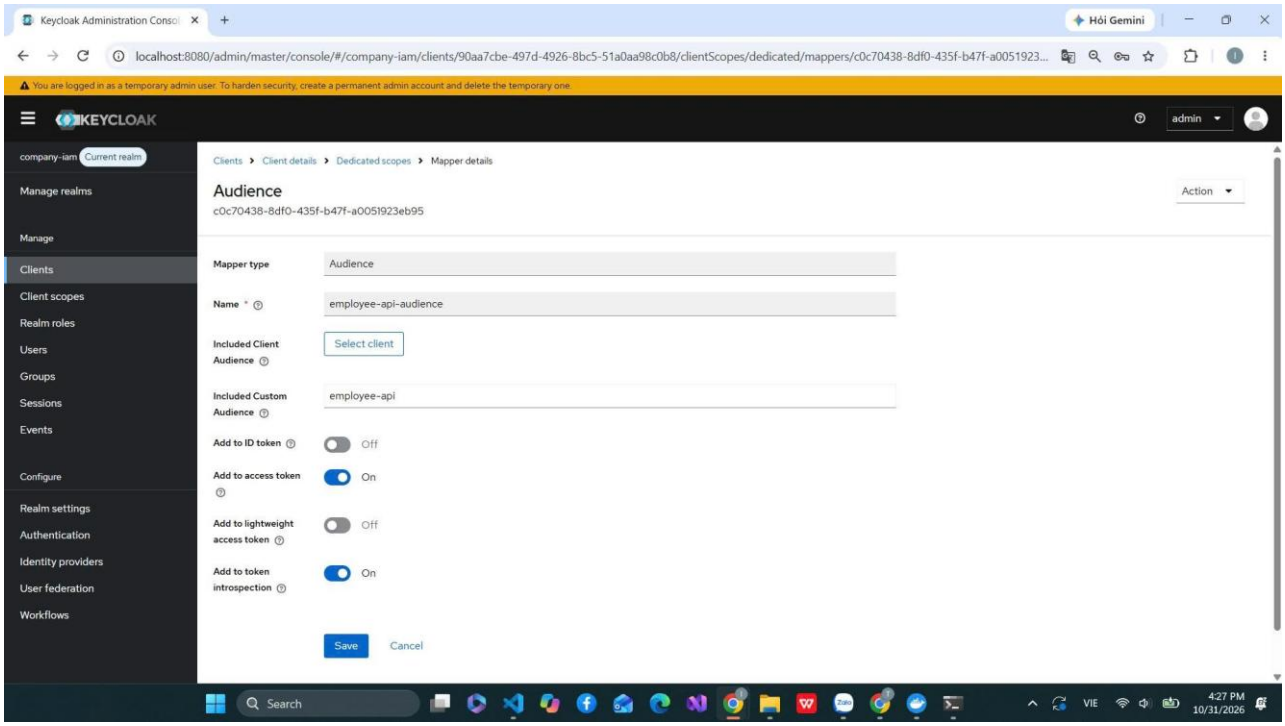


Hình 2.1. Cấu hình Authorization Code Flow và PKCE S256 của employee-portal.

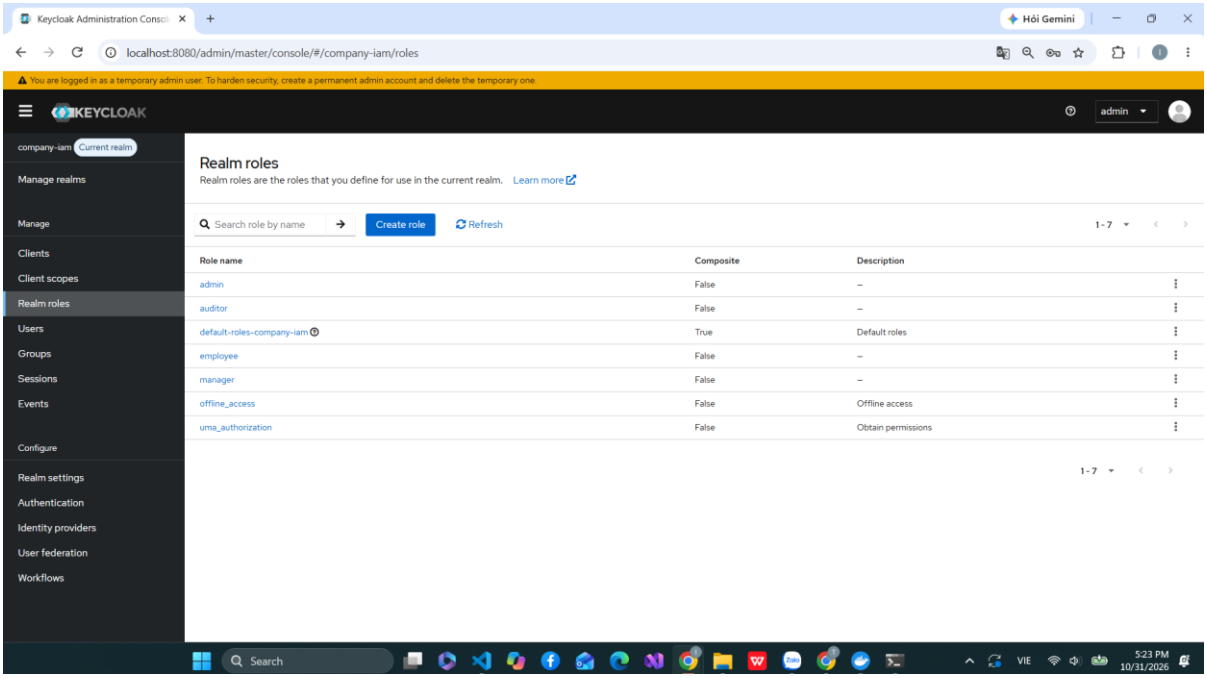
2.2. Cấu hình Audience và ánh xạ vai trò

Thiết lập audience mapper để Access Token có đối tượng nhận employee-api; gắn client scope roles để backend đọc các realm role trong realm_access.roles. Bốn vai trò ứng dụng được đặt tên chính xác là admin, manager, employee và auditor. Backend đối chiếu audience khi xác minh JWT, sau đó kiểm tra vai trò trước khi trả dữ liệu.

Kết quả: Đã đối chiếu cấu hình trên Keycloak và kiểm tra issuer, audience của token ở cả bốn tài khoản trong lượt kiểm thử thực tế.



Hình 2.2. Audience mapper đưa employee-api vào Access Token.

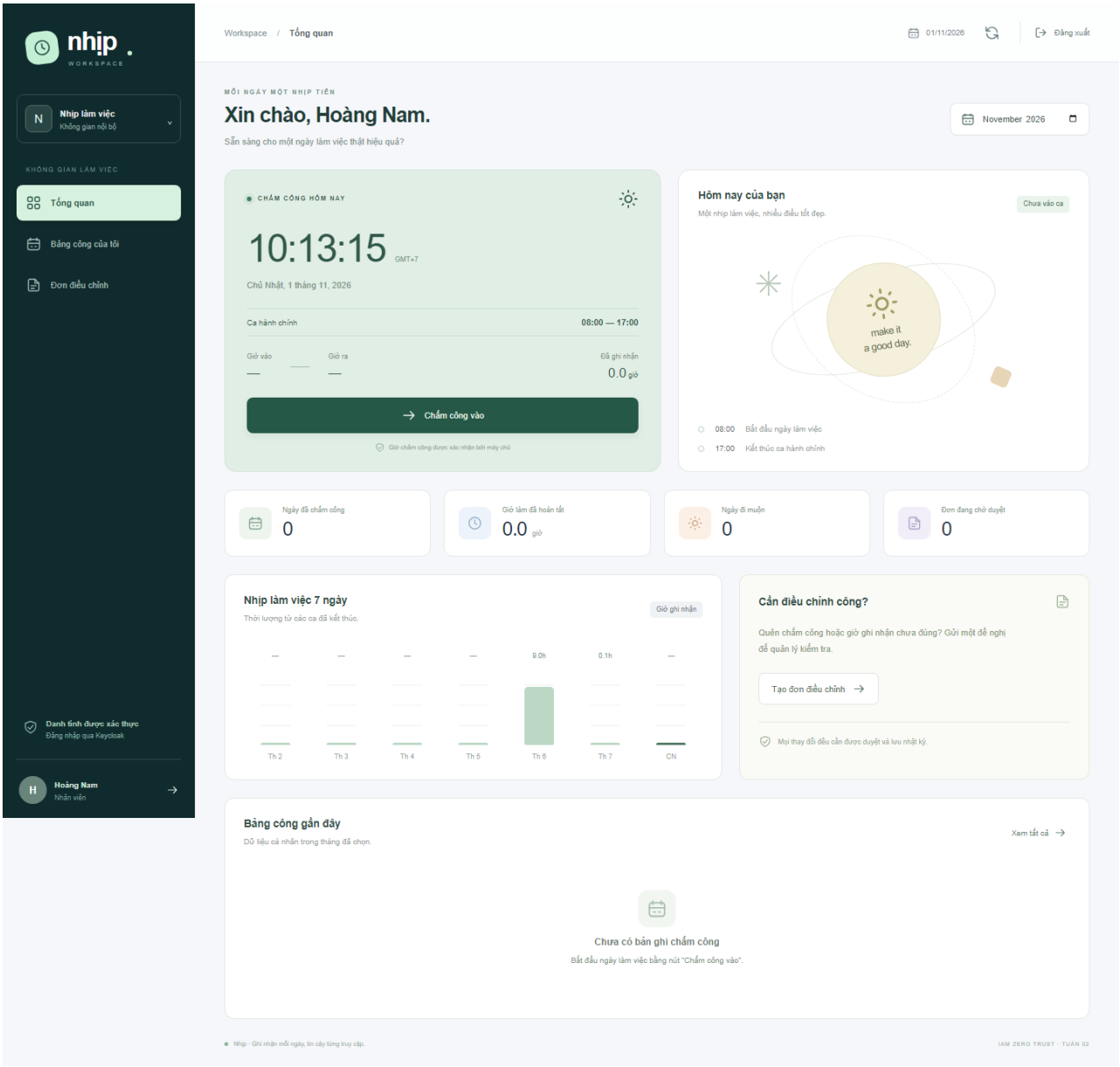


Hình 2.3. Bốn realm role admin, manager, employee và auditor trong Keycloak.

2.3. Xây dựng giao diện Web A bằng React

Xây dựng Web A bằng React với giao diện Nhịp Workspace, hỗ trợ máy tính và điện thoại. Ứng dụng hiển thị hồ sơ, vai trò, chấm công cá nhân và các chức năng theo quyền. Menu được điều chỉnh theo tài khoản; mọi yêu cầu API vẫn phải được backend kiểm tra độc lập. Token được sử dụng trong bộ nhớ phiên của keycloak-js, không đưa vào ảnh minh chứng.

Kết quả: Đã kiểm tra đăng nhập và đăng xuất của employee01, manager01, admin01, auditor01; giao diện tải dữ liệu hồ sơ thành công sau đăng nhập.



Hình 2.4. Giao diện Nhịp Workspace sau khi employee01 đăng nhập.

2.4. Xây dựng Backend API và phân quyền RBAC

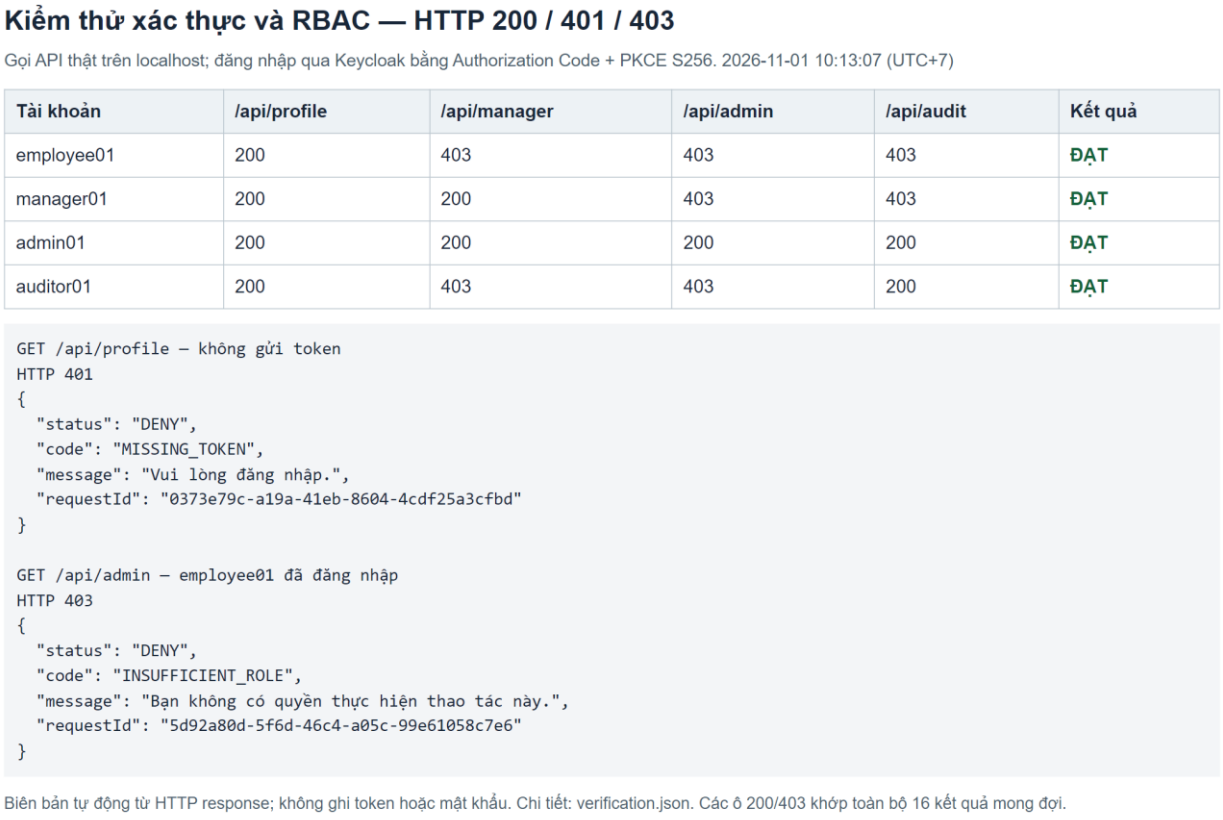
Backend Node.js/Express nhận Bearer Token và dùng thư viện jose xác minh chữ ký RS256 bằng JWKS của Keycloak; kiểm tra issuer, audience, thời hạn và các claim bắt buộc sub, iat, exp. Danh tính sub được đối chiếu với hồ sơ nhân viên phía server; vai trò trong JWT phải khớp vai trò của hồ sơ. Cơ chế này áp dụng trước khi xử lý các API /api/profile, /api/manager, /api/admin và /api/audit.

Quy tắc RBAC: các tài khoản đã được cấp hồ sơ và vai trò hợp lệ đều được đọc /api/profile; manager và admin được đọc /api/manager; chỉ admin được đọc /api/admin; admin và auditor được đọc /api/audit. Kết quả: API từ chối thiếu token bằng HTTP 401 và từ chối sai quyền bằng HTTP 403; kết quả đối chiếu được trình bày tại mục 2.5.

2.5. Kiểm thử xác thực và phân quyền

Đăng nhập lần lượt bằng bốn tài khoản demo qua Keycloak thật và gọi bốn API để đối chiếu 16 kết quả với ma trận RBAC. HTTP 200 xác nhận yêu cầu có token hợp lệ và đủ quyền. Khi không gửi token đến /api/profile, backend trả HTTP 401, status DENY và code MISSING_TOKEN. Khi employee01 gọi /api/admin bằng token hợp lệ, backend trả HTTP 403 với code INSUFFICIENT_ROLE. Các phản hồi được lưu trong verification.json, không lưu token hoặc mật khẩu.

Kết quả kiểm chứng ngày 01/11/2026: toàn bộ 16 yêu cầu theo vai trò trả đúng HTTP 200/403; trường hợp thiếu token trả đúng HTTP 401. Chạy npm.cmd test trong backend đạt 54/54 bài kiểm thử, không có bài thất bại. Bộ backend sử dụng khóa JWT kiểm thử riêng, SQLite riêng và mô phỏng tương tác Keycloak; kết quả này được phân biệt với kiểm thử tích hợp Keycloak thật ở Hình 2.5.



Kiểm thử xác thực và RBAC — HTTP 200 / 401 / 403

Gọi API thật trên localhost; đăng nhập qua Keycloak bằng Authorization Code + PKCE S256. 2026-11-01 10:13:07 (UTC+7)

Tài khoản	/api/profile	/api/manager	/api/admin	/api/audit	Kết quả
employee01	200	403	403	403	ĐẠT
manager01	200	200	403	403	ĐẠT
admin01	200	200	200	200	ĐẠT
auditor01	200	403	403	200	ĐẠT

```
GET /api/profile — không gửi token
HTTP 401
{
  "status": "DENY",
  "code": "MISSING_TOKEN",
  "message": "Vui lòng đăng nhập.",
  "requestId": "0373e79c-a19a-41eb-8604-4cdf25a3cfbd"
}

GET /api/admin — employee01 đã đăng nhập
HTTP 403
{
  "status": "DENY",
  "code": "INSUFFICIENT_ROLE",
  "message": "Bạn không có quyền thực hiện thao tác này.",
  "requestId": "5d92a80d-5f6d-46c4-a05c-99e61058c7e6"
}
```

Biên bản tự động từ HTTP response; không ghi token hoặc mật khẩu. Chi tiết: verification.json. Các ô 200/403 khớp toàn bộ 16 kết quả mong đợi.

Hình 2.5. Biên bản API thực tế: ma trận RBAC và phản hồi HTTP 401/403.



Hình 2.6. Kết quả npm.cmd test: 54 bài kiểm thử backend đều đạt.

3. Kết quả đạt được trong tuần 3

- Hoàn thiện OIDC Client employee-portal: Authorization Code Flow, PKCE S256 và Audience employee-api.
- Xác nhận client scope roles và bốn realm role phục vụ phân quyền RBAC.
- Tích hợp đăng nhập, đăng xuất Keycloak và hiển thị dữ liệu người dùng trên Web A React.
- Xác minh JWT tại Backend Express, đối chiếu hồ sơ nhân viên và áp dụng quyền cho bốn API minh họa.
- Kiểm chứng HTTP 200, 401, 403 bằng Keycloak thật; ma trận 16 yêu cầu đúng kỳ vọng và bộ kiểm thử backend đạt 54/54.

4. Hạn chế và công việc tiếp theo

Hệ thống hiện là môi trường lab localhost, Keycloak dùng HTTP và start-dev; chưa triển khai HTTPS hoặc đánh giá vận hành thực tế. Các kết quả kiểm thử xác nhận các kịch bản đã thực hiện, chưa đủ để kết luận hệ thống đã đáp ứng đầy đủ kiến trúc Zero Trust hoặc không còn lỗ hổng.

Tuần tiếp theo dự kiến xây dựng Web B độc lập với OIDC Client riêng, kiểm thử SSO từ Web A sang Web B và hành vi đăng xuất ở cả hai ứng dụng. Trung tâm bảo mật hiện nằm trong Web A; MFA mới hỗ trợ yêu cầu cấu hình OTP theo tài khoản, chưa hoàn tất kiểm thử đăng ký thiết bị và đăng nhập bằng OTP.

Minh chứng: Hình 2.1–2.3 là ảnh cấu hình Keycloak đã có, được đối chiếu lại qua Admin API; Hình 2.4–2.6 được chụp trong lượt kiểm chứng ngày 01/11/2026. Tệp verification.json, backend-tests.tap và ảnh gốc được lưu tại word/minh_chung/tuan3. Các biên bản chỉ ghi kết quả cần đối chiếu, không chứa mật khẩu hoặc Access Token.